3

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad **Muhammed Salih Atiç** | Grup | Tarih **28.10.2026**

Kavram: Senaryo beş parçadır: kim → hangi kapı → ne yapar → zincir → **FİZİKSEL** sonuç. Skor = L × S × E (her biri 1–3). Kural: S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim → kapı → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
R1 · Fidye yazılımı grubu → oltalamayla çalınan, MFA'sız FADA servis hesabı → filo yönetim sunucusu üzerinden araçların hız ve rota parametrelerini değiştirir → yüklü araç beklenmedik hızda manevra yapar, hıza bağlı koruma alanı yanlış seçilir → **350 t yük devrilir veya çalışana çarpar; tüm filo durur.**	2	3	3	**18**	**Kritik**
R2 · İç tehdit / dikkatsiz bakım personeli → servis bilgisayarı ile tarayıcının konfigürasyon portu → "yanlış alarm veriyor" diye koruma alanını küçültür → araç insanı geç algılar → **araç ile kolon arasında ezilme.**	2	3	2	**12**	**Yüksek**
R3 · Tedarik zinciri saldırganı → yazılım güncelleme kanalına sızdırılmış imzasız navigasyon güncellemesi → konum hesabını kaydırır → araç tanımlı rota dışına, test alanındaki personelin bulunduğu bölgeye girer → **çarpma / ölümcül yaralanma.**	1	3	1	**3**	**Düşük skor, S=3 → öne alındı**

Kritik 18–27	Yüksek 9–17	Orta 4–8	Düşük 1–3

Ölçek: L = olasılık · S = insana etkinin şiddeti · E = maruziyet (insanın tehlike bölgesinde bulunma sıklığı). Trafo fabrikasında araç ile çalışanlar aynı zemini paylaştığı için E çoğunlukla yüksektir.

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   R1: imalat sektörüne en sık bu kapıdan (çalınan uzak erişim kimliği) giriliyor, tek bir hesap bütün filoyu etkiliyor ve sonuç doğrudan insan hayatı.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, **R3** (skor 3). Risk kaydında "S=3 bayrağı" taşır: skora bakılmaksızın kırmızı listeye alınır, her gözden geçirmede ele alınır ve bir sorumluya atanır. Gereksinim: yalnızca üretici imzalı ve doğrulanmış yazılım yüklenebilmeli. Ayrıca sertifikalı tarayıcı, navigasyon hatasında bile kişiyi algılamaya devam etmeli.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar? *(Üç senaryonun da son halkası fiziksel: çarpma, ezilme, yük devrilmesi.)*

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.